



COMPLIANCE POLICY MANUAL

Compliance Policy Manual

ORGANIZATION	Alpine Due Diligence Inc.
DOCUMENT TYPE	Consolidated Compliance Policies
VERSION	1.0
EFFECTIVE DATE	February 15, 2026
NEXT REVIEW	February 15, 2027
OWNER	Allen Zhang, Founder & CEO
CLASSIFICATION	Confidential

ALPINE DUE DILIGENCE

Introduction

This Compliance Policy Manual is the single consolidated reference for all information security, privacy, and compliance policies governing Alpine Due Diligence Inc. ("Alpine"). It is designed to be provided to clients, auditors, and regulators as evidence of Alpine's formal security program.

This manual encompasses all policies required for Alpine's pre-launch compliance posture, including client-facing policies (Privacy Policy, Terms of Service, Security Overview), internal governance policies (Information Security, Data Classification, Incident Response, Change Management, Acceptable Use, Vendor Management, Business Continuity), and legal templates (Data Processing Agreement, Risk Assessment).

Each policy is contained in a dedicated appendix and may be referenced independently. Together, they constitute Alpine's comprehensive security and compliance framework, aligned with the NIST Cybersecurity Framework (CSF) 2.0 and designed to support Alpine's SOC 2 certification roadmap.

All employees, contractors, and authorized users with access to Alpine systems are required to read this manual in its entirety and sign the Policy Acknowledgment Form (Appendix N). The signed form must be returned to azhang@alpinedd.com within 5 business days of receiving system access. Annual re-acknowledgment is required upon each revision of this manual.

Document Control

FIELD	VALUE
Version	1.0
Effective Date	February 15, 2026
Next Scheduled Review	February 15, 2027
Document Owner	Allen Zhang, Founder & CEO
Classification	Confidential
Distribution	Authorized personnel, clients, and auditors

Appendix Index

APPENDIX	POLICY	CATEGORY
A	Privacy Policy	Client-facing
B	Terms of Service	Client-facing
C	Security Overview	Client-facing
D	Information Security Policy	Internal
E	Data Classification & Handling	Internal
F	Data Retention & Disposal	Internal
G	Incident Response Plan	Internal
H	Change Management Policy	Internal
I	Acceptable Use Policy	Internal

J	Vendor Management Policy	Internal
K	Business Continuity Plan	Internal
L	Data Processing Agreement	Legal
M	Risk Assessment	Legal
N	Policy Acknowledgment Form	Required

ALPINE DUE DILIGENCE

Appendix A: Privacy Policy

Effective Date: February 15, 2026 | Last Updated: February 15, 2026 | Published at: alpinedd.com/privacy

1. Introduction

Alpine Due Diligence Inc. ("Alpine," "we," "our," or "us") operates an AI-powered operational due diligence analysis platform at alpinedd.com (the "Service"). This Privacy Policy describes how we collect, use, store, and protect information when you use our Service.

We are committed to protecting the confidentiality and security of all information entrusted to us by our clients. This policy applies to all users of the Alpine platform, including individual analysts and institutional clients.

2. Information We Collect

2.1 Account Information

- Name, email address, and organizational affiliation provided during account registration.
- Authentication credentials (passwords are stored using industry-standard bcrypt hashing; Alpine never stores plaintext passwords).
- Role and permission assignments configured by your organization.

2.2 Uploaded Documents

- Fund documents, DDQs, regulatory filings, and other materials uploaded by authorized users for analysis.
- All uploaded documents are treated as Confidential data under our Data Classification Policy (Appendix C).

2.3 Generated Content

- Analysis reports, risk assessments, and other outputs produced by the Service.
- User annotations, comments, and custom configurations applied to reports.

2.4 Usage Logs

- Timestamps, IP addresses, and browser metadata associated with platform access.
- Feature usage patterns and performance telemetry (anonymized and aggregated).

3. How We Use Your Information

- Analysis Only: Uploaded documents are processed solely to generate due diligence reports for the uploading client. Documents are never used for marketing, profiling, or any purpose unrelated to the requested analysis.
- Service Improvement: Anonymized, aggregated benchmarking data (e.g., average topic coverage rates) may be used to improve analytical frameworks. No client-identifiable data is included in benchmarks.
- Security & Compliance: Usage logs are retained to support audit trails, incident investigation, and regulatory compliance.

4. How We Store and Protect Your Data

- Encryption at Rest: All data stored on Alpine servers is encrypted using AES-256 encryption.
- Encryption in Transit: All communications between your browser and Alpine servers use TLS 1.3.
- Access Controls: Role-based access control (RBAC), JWT-based authentication, session management, and automatic account lockout after repeated failed login attempts.
- Audit Logging: Every access event is logged with timestamp, user identity, and action performed.
- Infrastructure: Alpine operates on dedicated servers hosted by Hetzner Online GmbH (ISO 27001 certified), located

in the European Union.

5. Data Retention

DATA TYPE	RETENTION PERIOD	DISPOSAL
Uploaded documents	Engagement + 90 days	Secure overwrite
Generated reports	Duration of engagement	Deleted on request
Audit logs	1 year minimum	Archived, then deleted
Account data	Account duration + 30 days	Database deletion
Anonymized benchmarks	Indefinite	N/A (no PII)
Backups	30 days rolling	Encrypted overwrite

For full details, see Appendix D: Data Retention & Disposal Policy.

6. Third-Party Data Processing

Alpine uses the Anthropic API (Claude) for AI-powered document analysis. This processing is governed by:

- Anthropic Commercial API Terms of Service, which prohibit model training on customer data.
- A Data Processing Agreement (DPA) executed with Anthropic.
- Zero Data Retention (ZDR) enabled on our API account, meaning document text sent for analysis is not stored by Anthropic after the API response is returned.

No other third parties receive or have access to client document content.

7. Your Rights

- Access: You may request a summary of the personal data we hold about you.
- Deletion: You may request deletion of your data at any time. Alpine will complete deletion within 30 business days and send a written confirmation.
- Portability: You may request export of your uploaded documents and generated reports.
- Opt-Out: You may opt out of anonymized benchmarking by contacting us.

8. Contact

For privacy inquiries, data requests, or complaints:

Email: azhang@alpinedd.com

Alpine Due Diligence Inc.

ALPINE DUE DILIGENCE

Appendix B: Terms of Service

Effective Date: February 15, 2026 | Published at: alpinedd.com/terms

1. Service Description

Alpine Due Diligence Inc. ("Alpine") provides an AI-powered operational due diligence (ODD) analysis platform (the "Service"). The Service enables institutional investors and their advisors to upload fund documentation, perform automated gap analysis, generate structured ODD reports, and conduct independent verification checks.

2. Account Responsibilities

- You are responsible for maintaining the confidentiality of your account credentials.
- You must not share login credentials with unauthorized individuals.
- You must use the Service only for authorized business purposes consistent with your organization's engagement with Alpine.
- You must notify Alpine immediately of any suspected unauthorized access to your account.

3. Data Ownership

- Client Data: You retain all ownership rights to documents you upload and any data you provide to the Service. Alpine acquires no ownership interest in client data.
- Alpine IP: Alpine retains ownership of its analytical frameworks, methodologies, scoring algorithms, software, and platform infrastructure. Generated reports contain Alpine's proprietary analytical framework applied to your data.
- Report License: You receive a non-exclusive, non-transferable license to use reports generated by the Service for your internal business purposes.

4. Limitation of Liability

THE SERVICE PROVIDES ANALYTICAL OUTPUTS TO SUPPORT YOUR DUE DILIGENCE PROCESSES. ALPINE DOES NOT PROVIDE INVESTMENT ADVICE, LEGAL ADVICE, TAX ADVICE, OR ACCOUNTING ADVICE. Reports generated by the Service are intended to supplement, not replace, professional judgment by qualified analysts and advisors.

To the maximum extent permitted by law, Alpine's total liability for any claims arising from use of the Service shall not exceed the fees paid by you to Alpine in the twelve (12) months preceding the claim. Alpine shall not be liable for indirect, consequential, incidental, or punitive damages.

5. Confidentiality

Alpine treats all client data as confidential. We will not disclose client data to third parties except as necessary to provide the Service (e.g., API processing as described in our Privacy Policy), as required by law, or with your written consent. All Alpine personnel are bound by confidentiality obligations.

6. Termination

- Either party may terminate the Service agreement with 30 days' written notice.
- Upon termination, Alpine will delete all client data within 30 days, unless retention is required by law or regulation.
- You may request immediate deletion of specific documents at any time.
- Alpine may suspend or terminate accounts that violate these Terms or the Acceptable Use Policy.

7. Disclaimer

THE SERVICE IS PROVIDED "AS IS" AND "AS AVAILABLE." ALPINE MAKES NO WARRANTIES, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, OR NON-INFRINGEMENT. Alpine does not guarantee the accuracy, completeness, or timeliness of any analysis output. Users should independently verify all findings before making investment decisions.

8. Governing Law

These Terms shall be governed by and construed in accordance with applicable law. Any disputes shall be resolved through binding arbitration.

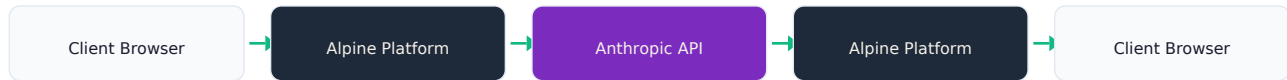
ALPINE DUE DILIGENCE

Appendix C: Security Overview

This document provides a high-level overview of Alpine's security architecture and controls.

Data Flow Architecture

All client data follows a controlled, auditable path through the Alpine platform:



TLS 1.3 encryption protects data in transit at every stage. The Anthropic API processes document text transiently under Zero Data Retention (ZDR) terms; no client data is stored by Anthropic.

Encryption Standards

LAYER	STANDARD	DETAILS
In Transit	TLS 1.3	All API and browser connections
At Rest	AES-256	Server disk encryption (Hetzner)
Backups	AES-256	Encrypted daily automated backups
Passwords	bcrypt	Salted + hashed, never stored plaintext

Access Controls

- Role-Based Access Control (RBAC): Users are assigned roles with granular permissions.
- JWT Authentication: Stateless, cryptographically signed session tokens with expiry.
- Session Management: Automatic timeout after inactivity. Concurrent session limits.
- Account Lockout: Accounts locked after 5 consecutive failed login attempts.
- Audit Logging: Every access event logged with timestamp, user identity, IP, and action.

AI Data Handling

- Alpine uses Anthropic's Commercial API, which explicitly prohibits training on customer data.
- A Data Processing Agreement (DPA) is in place with Anthropic.
- Zero Data Retention (ZDR) is enabled: API inputs and outputs are not stored by Anthropic.
- No client data is used for model training, fine-tuning, or any purpose beyond generating the requested analysis.

Compliance Roadmap

MILESTONE	TARGET DATE	STATUS
NIST CSF 2.0 Alignment	Q1 2026	In Progress
SOC 2 Type I Audit	Q2 2026	Planned
SOC 2 Type II Audit	Q4 2026	Planned
Penetration Test	Q2 2026	Planned

ALPINE DUE DILIGENCE

Appendix D: Information Security Policy

Owner: Allen Zhang, Founder & CEO | Review Cycle: Annual

1. Purpose

This policy establishes the framework for protecting the confidentiality, integrity, and availability of all information assets owned, processed, or managed by Alpine Due Diligence Inc. It applies to all Alpine systems, data, personnel, and contractors.

2. Scope

This policy applies to all Alpine information systems, networks, applications, data repositories, and cloud services, as well as all personnel, contractors, and third parties who access Alpine systems or data.

3. Roles and Responsibilities

ROLE	RESPONSIBILITY	CURRENT HOLDER
Security Lead	Overall security program ownership	Allen Zhang (Founder)
System Admin	Server hardening, patching, monitoring	Allen Zhang (Founder)
Data Owner	Classification, access decisions	Allen Zhang (Founder)
CCO (future)	Compliance oversight, audit liaison	TBD (hire planned)

Note: As a solo founder, Allen Zhang currently fulfills all security roles. Responsibilities will be delegated as the team grows.

4. Data Classification

All Alpine data is classified into one of three categories. See Appendix E for full handling procedures.

CLASSIFICATION	DESCRIPTION	EXAMPLES
Public	No sensitivity; freely shareable	Website, marketing, published policies
Internal	Business-sensitive; internal only	Source code, architecture, strategy
Confidential	Highly sensitive; restricted access	Client docs, reports, user data

5. Access Control Principles

- Least Privilege: Users receive only the minimum permissions required for their role.
- Need-to-Know: Access to Confidential data is granted only when required for a specific business function.
- Separation of Duties: Where feasible, no single individual should control all aspects of a critical process (note: limited applicability as a solo founder; compensating controls include audit logging and documented self-review).
- Authentication: All access requires strong authentication. Multi-factor authentication will be required for administrative access once implemented.

6. Acceptable Use

All users of Alpine systems must comply with the Acceptable Use Policy (Appendix I). Key requirements include:

- Systems are for authorized business use only.
- No sharing of credentials under any circumstances.
- No downloading of client data to personal or unauthorized devices.
- All security incidents must be reported immediately.

7. Incident Management

All security incidents must be reported, assessed, and resolved according to the Incident Response Plan (Appendix F). Key obligations:

- Report suspected incidents immediately to the Security Lead.
- Affected clients will be notified within 72 hours of a confirmed data breach.
- Post-incident reviews are mandatory for all P1 and P2 severity incidents.

8. Policy Review

This policy and all appendices will be reviewed at least annually, or sooner if triggered by a significant security incident, change in business operations, or regulatory update. All reviews will be documented with date, reviewer, and changes made.

9. Acknowledgment

I acknowledge that I have read, understood, and agree to comply with this Information Security Policy and all referenced appendices.

Allen Zhang, Founder & CEO

Date: _____

ALPINE DUE DILIGENCE

Appendix E: Data Classification & Handling

1. Purpose

This policy defines data classification levels and the specific handling, storage, transmission, and disposal requirements for each level. It ensures that all Alpine personnel apply consistent and appropriate protections to information based on its sensitivity.

2. Classification Levels

2.1 Public

Information intended for public consumption. No confidentiality requirements. Examples: website content, published policies, marketing materials, blog posts.

2.2 Internal

Information intended for use within Alpine only. Disclosure could cause minor business impact. Examples: internal source code, architecture documentation, business strategy, internal communications.

2.3 Confidential

Highly sensitive information whose unauthorized disclosure could cause significant harm to Alpine or its clients. Examples: client-uploaded documents, generated ODD reports, analysis outputs, user account data, API keys, encryption keys.

3. Handling Requirements

REQUIREMENT	PUBLIC	INTERNAL	CONFIDENTIAL
Encryption at Rest	Not required	Required	Required (AES-256)
Encryption in Transit	Recommended	Required (TLS)	Required (TLS 1.3)
Access Control	None	Auth required	RBAC + need-to-know
Audit Logging	Not required	Recommended	Required (all access)
Backup	Not required	Standard backup	Encrypted backup
Sharing	Unrestricted	Alpine personnel	Named individuals only
Disposal	Standard delete	Secure delete	Secure overwrite + log
Labeling	None	"Internal"	"Confidential"

4. Classification Responsibilities

- Data Owner (currently: Founder) is responsible for assigning classification levels to new data types.
- All client-provided data defaults to Confidential unless explicitly determined otherwise.
- When in doubt, classify at the higher sensitivity level.
- Classification must be reviewed whenever data is repurposed or combined with other data.

ALPINE DUE DILIGENCE

Appendix F: Data Retention & Disposal

1. Purpose

This policy establishes retention periods and secure disposal procedures for all data types processed by Alpine. It ensures data is retained only as long as necessary for business and legal requirements, and is securely destroyed when no longer needed.

2. Retention Schedule

DATA TYPE	RETENTION PERIOD	DISPOSAL METHOD
Uploaded client documents	Engagement + 90 days	Secure deletion (overwrite)
Generated reports	Duration of engagement	Secure deletion on request
Audit logs	1 year minimum	Archived, then secure deletion
User account data	Account + 30 days	Database deletion
Anonymized benchmarks	Indefinite	N/A (no client-identifiable data)
Backups	30 days rolling	Encrypted overwrite
Session tokens	24 hours	Automatic expiry + deletion

3. Secure Disposal Procedures

3.1 Digital Files (Documents, Reports)

- Files are overwritten using a secure deletion utility before filesystem removal.
- Deletion is logged in the audit trail with timestamp, file identifier, and initiating user.

3.2 Database Records

- Records are permanently deleted from the primary database using standard SQL DELETE operations.
- Database backups containing the deleted records will age out within the 30-day rolling backup window.

3.3 Backups

- Backup files are encrypted at rest and automatically overwritten on the 30-day rolling schedule.
- In the event of client data deletion requests, the data will be fully purged once all backup copies age out.

4. Client Deletion Requests

Clients may request deletion of their data at any time by contacting azhang@alpinedd.com. Alpine will:

- Acknowledge the request within 2 business days.
- Complete deletion from primary systems within 30 business days.
- Confirm deletion in writing to the requesting client.
- Note that backup copies will age out within the rolling 30-day backup window.

5. Exceptions

Data may be retained beyond the standard retention period if required by law, regulation, or active legal proceeding. Any such exceptions will be documented with the legal basis and expected additional retention period.

ALPINE DUE DILIGENCE

Appendix G: Incident Response Plan

Security incident response is critical to maintaining client trust and regulatory compliance.

1. Purpose

This plan establishes procedures for detecting, assessing, containing, remediating, and reporting information security incidents affecting Alpine systems or data.

2. Severity Classification

SEVERITY	DESCRIPTION	RESPONSE TIME	EXAMPLE
P1 Critical	Active breach of client data	Immediate	Unauthorized data exfiltration
P2 High	System compromise, no data loss	< 4 hours	Server intrusion detected
P3 Medium	Vulnerability found, unexploited	< 24 hours	Unpatched CVE on server
P4 Low	Minor security event	< 72 hours	Brute-force login attempts blocked

3. Response Phases

Phase 1: Detection

- Automated monitoring: Server health checks, intrusion detection, log analysis.
- User reports: Clients or team members reporting suspicious activity.
- External notification: Alerts from vendors (Hetzner, Anthropic) or security researchers.

Phase 2: Assessment

- Determine scope: What systems and data are affected?
- Classify severity using the table above.
- Document initial findings with timestamps.

Phase 3: Containment

- Revoke compromised credentials immediately.
- Isolate affected systems from the network if necessary.
- Preserve forensic evidence (logs, disk images) before remediation.

Phase 4: Eradication

- Identify and remove the root cause (patch vulnerability, remove malware, etc.).
- Reset all potentially compromised credentials.
- Verify eradication through system scanning and log review.

Phase 5: Recovery

- Restore systems from clean backups if necessary.
- Verify system integrity before returning to production.
- Implement additional monitoring for the affected systems.

Phase 6: Notification

AUDIENCE	TIMELINE	METHOD
Internal (Security Lead)	Immediately upon detection	Direct communication
Affected clients	Within 72 hours of confirmed breach	Email + phone call
Regulators	As required by applicable law	Written notification
Anthropic / Hetzner	As needed for investigation	Support channels

Phase 7: Post-Incident Review

- Conduct root cause analysis within 5 business days of incident resolution.
- Document lessons learned and corrective actions.
- Update controls, policies, or procedures as needed.
- File the post-incident report in the security documentation repository.

4. Emergency Contacts

CONTACT	ROLE	METHOD
Allen Zhang	Security Lead / Founder	Phone + Email
Hetzner Support	Infrastructure provider	Support portal + phone
Anthropic Support	AI API provider	Support portal

5. Testing

Alpine will conduct at least one tabletop exercise annually to test this incident response plan. The exercise will simulate a P1 or P2 scenario and walk through all response phases. Results and improvements will be documented.

ALPINE DUE DILIGENCE

Appendix H: Change Management Policy

1. Purpose

This policy ensures that all changes to Alpine production systems are planned, tested, documented, and reversible, minimizing the risk of service disruption or security compromise.

2. Scope

This policy applies to all changes to production code, server configurations, database schemas, infrastructure, and third-party integrations.

3. Change Process

3.1 Standard Changes

1. All code changes are committed through Git version control. No direct edits to production systems.
2. Code review is required before merge. For the solo founder, documented self-review is acceptable. Each review must include a summary of changes, security implications, and test results.
3. Testing must be performed before deployment. At minimum: manual smoke test of the critical user flow (document upload, analysis, report generation, PDF download).
4. Deployment procedure: git pull on production server, restart affected services, execute smoke test, verify via monitoring dashboards.
5. All deployments are logged with date, time, commit hash, and summary of changes.

3.2 Rollback Procedure

1. Identify the issue and the commit that introduced it.
2. Execute git revert to reverse the problematic changes.
3. Restart affected services.
4. Run smoke test to verify system stability.
5. Document the rollback event, root cause, and follow-up actions.

3.3 Emergency Changes

In the event of a critical security vulnerability or production outage requiring immediate remediation:

- The standard change process may be abbreviated, but all changes must still go through Git.
- Emergency changes must be fully documented within 24 hours of implementation.
- A post-change review must be conducted to determine if the emergency process was appropriate.

4. Change Log

The Git commit history serves as the primary change log. Each commit message must include a clear description of what was changed and why. Major changes should reference a ticket or issue number.

ALPINE DUE DILIGENCE

Appendix I: Acceptable Use Policy

1. Purpose

This policy defines acceptable and prohibited uses of Alpine systems, networks, and data. It applies to all personnel, contractors, and users with access to Alpine systems.

2. Acceptable Use

- Alpine systems, applications, and data are to be used solely for authorized business purposes related to Alpine's operations and client engagements.
- Users must access only the data and systems necessary for their assigned responsibilities.
- Users must comply with all applicable laws and regulations when using Alpine systems.

3. Prohibited Activities

- Sharing account credentials with any other person, including colleagues.
- Downloading, copying, or transferring client data to personal devices, unauthorized storage locations, or personal cloud accounts.
- Accessing client data without a legitimate business justification.
- Attempting to bypass, disable, or circumvent any security control.
- Using Alpine systems for any illegal, fraudulent, or unauthorized purpose.
- Installing unauthorized software on Alpine infrastructure.
- Disclosing confidential information to unauthorized parties.

4. Reporting Obligations

All users must report any suspected or actual security incident, policy violation, or unauthorized access immediately to the Security Lead (azhang@alpinedd.com). Failure to report known incidents is itself a policy violation.

5. Enforcement

Violations of this policy may result in disciplinary action up to and including account suspension, termination of access, termination of employment or contract, and/or legal action. The severity of the response will be proportional to the nature and impact of the violation.

6. Future Expansion

This policy will be expanded as the Alpine team grows to include additional provisions for BYOD (Bring Your Own Device), remote access, social media use, and other topics as appropriate.

ALPINE DUE DILIGENCE

Appendix J: Vendor Management Policy

1. Purpose

This policy establishes requirements for evaluating, engaging, and monitoring third-party vendors that provide services to Alpine or have access to Alpine systems or data.

2. Vendor Evaluation Criteria

Before engaging any vendor that will process, store, or access Alpine or client data, the following must be assessed:

- Security certifications (SOC 2, ISO 27001, or equivalent).
- Data processing agreement (DPA) availability and terms.
- Data residency and jurisdictional compliance.
- Incident notification and breach response commitments.
- Encryption and access control capabilities.
- Business continuity and disaster recovery provisions.

3. Current Vendor Inventory

VENDOR	SERVICE	DATA ACCESS	CERTIFICATIONS	DPA
Anthropic	AI API	Doc text (transient)	SOC 2 Type II	Yes + ZDR
Hetzner	Server hosting	Full (encrypted)	ISO 27001	Yes
Let's Encrypt	SSL certificates	None	N/A	N/A
GitHub	Code repository	Source code only	SOC 2 Type II	Yes

4. Ongoing Vendor Monitoring

- All vendors are reviewed annually for continued compliance with Alpine's security requirements.
- Vendors must notify Alpine of any material changes to their security posture or data handling practices.
- Vendor certifications (SOC 2 reports, ISO certificates) are reviewed upon renewal or when updated versions are issued.
- Any vendor security breach that may affect Alpine data triggers an immediate review and assessment.

5. Vendor Offboarding

When a vendor relationship is terminated, Alpine will ensure all Alpine data held by the vendor is securely deleted or returned, access credentials are revoked, and the vendor is removed from the approved vendor inventory.

ALPINE DUE DILIGENCE

Appendix K: Business Continuity Plan

1. Purpose

This plan ensures Alpine can maintain or quickly restore critical business operations in the event of a disruption. It defines recovery objectives, critical systems, disruption scenarios, and response procedures.

2. Recovery Objectives

OBJECTIVE	TARGET	DESCRIPTION
RTO (Recovery Time)	4 hours	Maximum time to restore services
RPO (Recovery Point)	24 hours	Maximum acceptable data loss

3. Critical Systems Inventory

SYSTEM	PROVIDER	CRITICALITY	BACKUP STRATEGY
Application Server	Hetzner	Critical	Daily encrypted backups
Anthropic API	Anthropic	Critical	Graceful degradation msg
Code Repository	GitHub	High	Local mirrors + Git history
DNS	Domain registrar	High	Document nameserver config
SSL Certificates	Let's Encrypt	High	Auto-renewal + manual backup

4. Disruption Scenarios

4.1 Server Failure

1. Detect failure via monitoring alerts or user reports.
2. Provision a new Hetzner server instance.
3. Restore application and data from the most recent encrypted backup.
4. Update DNS if IP address has changed.
5. Run smoke test to verify full functionality.
6. Notify affected clients if outage exceeded 4 hours.

4.2 Anthropic API Outage

1. Detect via API error responses or monitoring.
2. Display user-facing message: "AI analysis temporarily unavailable. Document upload and report viewing remain functional."
3. Queue pending analysis requests for automatic retry.
4. Monitor Anthropic status page for resolution timeline.

4.3 DNS Failure

1. Contact domain registrar support.
2. Update nameserver records as needed.
3. Verify propagation using external DNS lookup tools.

4.4 Founder Unavailable

Current single point of failure acknowledged. Mitigations:

- All procedures documented in this manual to enable handoff.
- Infrastructure credentials stored in encrypted password manager.
- Plan: address with co-founder or operations hire as team grows.

5. Backup Procedures

- Daily automated encrypted backups of all application data and databases.
- Backups stored on separate infrastructure from the primary server.
- Backup integrity tested quarterly by performing a test restoration.
- 30-day rolling retention for all backups.

6. Communication Plan

If a service disruption exceeds 4 hours, Alpine will notify all active clients via email with: (1) description of the issue, (2) estimated time to resolution, (3) any actions required by the client, and (4) a follow-up communication upon resolution.

ALPINE DUE DILIGENCE

Appendix L: Data Processing Agreement

Template: To be executed between Alpine Due Diligence Inc. ("Processor") and each client ("Controller"). Legal review recommended before use.

1. Scope of Processing

The Processor will process personal data and confidential business data solely for the purpose of providing the operational due diligence analysis services described in the Service Agreement. Processing activities include: document ingestion, AI-powered analysis, report generation, and secure storage during the engagement.

2. Categories of Data

- Fund documentation (PPMs, DDQs, audited financials, organizational charts)
- Regulatory filing data (SEC registrations, ADV forms)
- Business correspondence related to fund operations
- Any personal data contained within the above documents

3. Sub-Processors

The Processor engages the following sub-processors:

SUB-PROCESSOR	PURPOSE	DATA HANDLED	SAFEGUARDS
Anthropic	AI analysis API	Document text (transient)	DPA + ZDR + no training
Hetzner	Infrastructure	All data (encrypted at rest)	ISO 27001 + DPA

The Processor will notify the Controller of any changes to sub-processors at least 30 days in advance.

4. Security Obligations

The Processor will implement and maintain the technical and organizational security measures described in Appendix C (Security Overview) and Appendix D (Information Security Policy), including but not limited to:

- Encryption of data at rest (AES-256) and in transit (TLS 1.3).
- Role-based access controls and audit logging.
- Regular security assessments and vulnerability management.

5. Breach Notification

In the event of a personal data breach, the Processor will notify the Controller without undue delay and in any event within 72 hours of becoming aware of the breach. Notification will include: (a) nature of the breach, (b) categories and approximate number of records affected, (c) likely consequences, and (d) measures taken or proposed to address the breach.

6. Data Deletion

Upon termination of the Service Agreement, the Processor will delete all Controller data within 30 days and provide written confirmation of deletion. The Controller may request earlier deletion at any time during the engagement.

7. Audit Rights

The Controller may request evidence of the Processor's compliance with this Agreement. The Processor will make available relevant security documentation, audit reports (including SOC 2 reports when available), and compliance certifications. On-site audits may be conducted with 30 days' written notice, at the Controller's expense, no more than once per year.

8. Signatures

Authorized Signatory: Alpine Due Diligence Inc. (Processor)

Date: _____

Authorized Signatory: Client Organization (Controller)

Date: _____

ALPINE DUE DILIGENCE

Appendix M: Risk Assessment

Formal identification of threats, current controls, and residual risk.

1. Purpose

This risk assessment identifies and evaluates information security risks to Alpine systems and data, documents current controls, and determines residual risk levels. It informs prioritization of security investments and supports compliance requirements.

2. Methodology

Risks are evaluated on two dimensions: Likelihood (probability of occurrence) and Impact (severity of consequences if the risk materializes). Residual risk reflects the risk remaining after current controls are considered.

3. Risk Register

RISK	LIKELIHOOD	IMPACT	CONTROLS	RESIDUAL
Unauthorized data access	Medium	High	Auth + RBAC + audit + encryption	Low
API data exposure	Low	High	Commercial Terms + DPA + ZDR	Very Low
Server compromise	Low	High	Firewall + SSH + fail2ban + encryption	Low
Backup failure / data loss	Low	Medium	Daily encrypted backups + quarterly test	Low
Founder unavailable	Medium	Medium	BCP + documented procedures	Medium
Credential theft (phishing)	Medium	High	Strong passwords + lockout	Medium
Supply chain (vendor bre...	Low	High	Vendor DPAs + ZDR + annual review	Low
Insider threat	Low	High	Audit logging + least privilege	Low
Denial of service	Low	Medium	Rate limiting + Hetzner DDoS protection	Low
Regulatory non-compliance	Low	Medium	This policy manual + SOC 2 roadmap	Low

4. Risk Mitigation Priorities

High Priority (Address Immediately)

- Single point of failure (founder availability): Mitigate by documenting all procedures, storing credentials securely, and hiring operations support.
- Credential theft: Implement multi-factor authentication (MFA) for administrative access.

Medium Priority (Address Within 90 Days)

- Penetration testing: Engage an external security firm to conduct a penetration test.
- Formalize backup restoration testing with documented results.

Ongoing

- Maintain all current controls as documented in this manual.
- Review this risk assessment quarterly and update as the threat landscape evolves.

5. Review Schedule

This risk assessment will be reviewed and updated quarterly for the first year of operations, then annually thereafter. Material changes to Alpine's systems, data handling, or business operations will trigger an ad hoc review.

ALPINE DUE DILIGENCE

Appendix N: Policy Acknowledgment Form

REQUIRED: All Employees, Contractors & Authorized Users

Each individual with access to Alpine systems must sign this form and return it to:

azhang@alpinedd.com within 5 business days of receiving access.

Acknowledgment

By signing below, I acknowledge and confirm the following:

1. I have received, read, and understood the Alpine Due Diligence Compliance Policy Manual (Version 1.0, dated February 15, 2026), including all appendices listed herein.
2. I understand the policies, procedures, and standards described in this manual, including but not limited to the Information Security Policy (Appendix D), Data Classification & Handling Policy (Appendix E), Incident Response Plan (Appendix G), Acceptable Use Policy (Appendix I), and all other referenced policies.
3. I agree to comply with all policies contained in this manual in the performance of my duties. I understand that these policies apply to all Alpine systems, data, and resources that I access or use.
4. I understand that I must report any suspected or actual security incidents, policy violations, or unauthorized access immediately to the Security Lead at azhang@alpinedd.com.
5. I understand that failure to comply with these policies may result in disciplinary action, including suspension or termination of system access, termination of employment or contract, and/or legal action.
6. I understand that I will be required to re-acknowledge this manual annually or whenever a material revision is published, whichever occurs first.
7. I understand that the policies in this manual may be updated from time to time and that I am responsible for reviewing and complying with the most current version.

Signature

Full Name (Printed): _____

Title / Role: _____

Date: _____

Signature: _____

Submission Instructions

1. Print this page, sign and date it, then scan or photograph clearly.
2. Email the signed copy to azhang@alpinedd.com with subject line:
 "Policy Acknowledgment - [Your Full Name]"
3. Retain a personal copy for your records.